

Warsaw, July 12, 2023

Decision

DKN.5131.43.2022

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 755), Article 7 § 1, Article 60, Article 101, Article 101a § 2, and Article 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57 § 1 letters a) and h), Article 58 § 2 letters e) and i), Article 83 § 1 and § 2, Article 83 § 4 letter a) in connection with Article 33 § 1 and § 3 and Article 34 § 1, 2, and 4 of the Regulation of the European Parliament and Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of May 4, 2016, p. 1, OJ EU L 127 of May 23, 2018, p. 2, and OJ EU L 74 of March 4, 2021, p. 35), hereinafter referred to as the "Regulation 2016/679", after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by Ms. K.W., conducting business under the name W. with a place of business in O. at ul. (...), the President of the Personal Data Protection Office, finding that Ms. K.W., conducting business under the name W. with a place of business in O. at ul. (...) violated the provisions: a) Article 33 § 1 of Regulation 2016/679, consisting of failing to notify the President of the Personal Data Protection Office of the personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach, and b) Article 34 § 1 of Regulation 2016/679, consisting of failing to inform without undue delay the individuals whose data are concerned about the personal data breach, 1) imposes on Ms. K.W., conducting business under the name W. with a place of business in O. at ul. (...) an administrative fine in the amount of 11,790 PLN (in words: eleven thousand seven hundred ninety zlotys), 2) orders Ms. K.W., conducting business under the name W. with a place of business in O. at ul. (...) to notify – within 3 days from the date of delivery of this decision – the individuals whose data are concerned about the breach of their personal data protection in order to provide them with the information required under Article 34 § 2 of Regulation 2016/679, i.e.: a) a description of the nature of the personal data breach; b) the name and contact details of the data protection officer or the designation of another contact point from which more information can be obtained; c) a description of the possible consequences of the personal data breach; d) a description of the measures taken or proposed by the controller to address the breach – including measures to mitigate its possible negative effects.

JUSTIFICATION

To the President of the Personal Data Protection Office (hereinafter referred to as "the President of UODO") on (...) May 2022, an email was received from Ms. K.W., conducting business under the name W. with a place of business in O. at ul. (...), hereinafter referred to as "the Administrator", informing that "On (...) May, between 5:00 PM and 6:00 PM, a theft of documents from my laptop's desktop occurred using the UI application. The documents contained my clients' data, i.e.: First name, last name, sometimes residential addresses, email addresses, phone numbers, and occasionally PESEL numbers," along with a question about further proceedings.

In connection with the above, on (...) May 2022, the President of UODO informed the Administrator about the obligations arising from Article 33 § 1 and 3 of Regulation 2016/679, i.e., the obligation to notify the supervisory authority of the personal data breach. At the same time, the President of UODO informed the Administrator about possible ways to report the personal data breach to the supervisory authority. According to the return receipt confirmation, the aforementioned correspondence was delivered to the Administrator on (...) May 2022. Due to the fact that after the delivery of the correspondence, no explanations were received from the Administrator, on (...) July 2022, a follow-up letter was sent with information about possible ways to report the personal data breach to the supervisory authority. Furthermore, the President of UODO requested the Administrator, based on Article 58 § 1 letters a) and e) of Regulation 2016/679, to provide information on whether an analysis of the incident regarding the risk of infringement of the rights or freedoms of natural persons necessary to assess whether a personal data breach occurred, which would require notifying the President of

UODO and the individuals concerned about the breach, had been conducted. The repeated request for explanations was delivered to the Administrator, as indicated by the return receipt confirmation, on (...) July 2022. After the delivery of the correspondence, no explanations were received from the Administrator.

In connection with the above, the President of UODO on (...) September 2022 initiated ex officio administrative proceedings regarding the violation of personal data protection regulations in connection with the processing of personal data within the meaning of Regulation 2016/679 by the Administrator, indicating as the subject of the proceedings the possibility of a breach by the Administrator of the obligations arising from the provisions of Article 33(1) and Article 34(1) and (2) of Regulation 2016/679. At the same time, the President of the Personal Data Protection Office (UODO) once again requested the Administrator to indicate whether, in connection with the aforementioned situation, an analysis of the incident was conducted regarding the risk of infringement of the rights or freedoms of natural persons necessary to assess whether there was a breach of data protection resulting in the need to notify the President of the Personal Data Protection Office and the individuals concerned, as well as to indicate the number of individuals affected by the breach. The return confirmation of receipt indicates that the Administrator did not collect the notified shipment in due time. Consequently, on (...) November 2022, the President of the UODO again directed a notification to the Administrator regarding the initiation of administrative proceedings. The correspondence was delivered to the Administrator on (...) November 2022. After the delivery of the correspondence, no response was recorded regarding the notification of the initiation of administrative proceedings and the questions posed therein.

After reviewing all the evidence gathered in the case, the President of the Personal Data Protection Office considered the following: According to Article 4(12) of Regulation 2016/679, "a personal data breach" means a security breach that leads to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed. Article 33 of Regulation 2016/679 states that in the case of a personal data breach, the data controller shall notify the supervisory authority competent under Article 55 without undue delay - where feasible, not later than 72 hours after becoming aware of the breach - unless the breach is unlikely to result in a risk to the rights or freedoms of natural persons. A notification submitted to the supervisory authority after the 72-hour period must include an explanation of the reasons for the delay (paragraph 1). The notification referred to in paragraph 1 must at least: a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects affected, as well as the categories and approximate number of personal data records concerned; b) contain the name and contact details of the data protection officer or another contact point from which more information can be obtained; c) describe the likely consequences of the personal data breach; d) describe the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects (paragraph 3).

In turn, Article 34(1) of Regulation 2016/679 indicates that in situations where a personal data breach is likely to result in a high risk to the rights or freedoms of natural persons, the controller is obliged to notify the data subject of such a breach without undue delay. According to Article 34(2) of Regulation 2016/679, a proper notification should: 1) describe the nature of the personal data breach in clear and plain language; 2) contain at least the information and measures referred to in Article 33(3)(b), (c), and (d) of Regulation 2016/679, i.e.: a) the name and contact details of the data protection officer or another contact point from which more information can be obtained; b) a description of the likely consequences of the personal data breach; c) a description of the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

The content of the aforementioned provisions of Regulation 2016/679 indicates that in the event of a personal data breach on the part of the data controller, there is an obligation to report it to the

President of the UODO if the breach is associated with a risk to the rights or freedoms of natural persons - regardless of the level of that risk. However, in situations where a personal data breach poses a high risk to the rights or freedoms of natural persons, the data controller is obliged to notify those individuals of the breach of their data protection.

There is no doubt that the event involving the theft of documents from a remote desktop using the application UI. (...) that occurred on (...) May 2022, given the scope of data indicated by the Administrator, constitutes a breach of data confidentiality due to the possibility of unauthorized access to the aforementioned data by an unauthorized person (persons). Consequently, it must be acknowledged that a security breach occurred resulting in at least unauthorized access to personal data processed by the Administrator, and thus a breach of personal data protection. At the same time, it should be noted that the scope of data covered by the breach, as provided by the Administrator in the correspondence sent electronically, which was received on (...) May 2022 (names, surnames, residential addresses, email addresses, phone numbers, and PESEL numbers), allows for the unequivocal identification of those individuals.

Reporting personal data breaches by controllers constitutes an effective tool contributing to a real improvement in the security of personal data processing. By reporting a breach to the supervisory authority, controllers inform the President of the UODO whether, in their assessment, there is a high risk of infringement of the rights or freedoms of the individuals concerned and - if such a risk exists - whether they have provided the relevant information to the individuals.

which the breach affects. In justified cases, they may also provide information that notification is not necessary in their opinion due to the fulfillment of the conditions specified in Article 34(3)(a) – (c) of Regulation 2016/679. The President of the UODO verifies the assessment made by the administrator and may – if the administrator has not notified the data subjects – request such notification from them. Reports of personal data breaches allow the supervisory authority to respond appropriately to mitigate the effects of such breaches, as the administrator is obliged to take effective actions to ensure the protection of individuals and their personal data, which on one hand allows for the monitoring of the effectiveness of existing solutions, and on the other hand, the assessment of modifications and improvements aimed at preventing irregularities similar to those covered by the breach.

It should be emphasized that the risk assessment of a breach of the rights or freedoms of an individual should be made through the lens of the affected person, not the interests of the administrator. This is particularly important, as based on the notification of a personal data breach, the individual can assess for themselves whether, in their opinion, the security incident may have negative consequences for them and take appropriate remedial actions. Also, based on the information provided by the administrator regarding the nature of the breach and the measures taken or proposed to remedy the breach, the individual can assess whether, following the breach, the data administrator still guarantees proper processing of their personal data in a manner that ensures their security. The lack of notification of a breach to the individual in the case of a high risk of infringement of their rights or freedoms deprives them not only of the opportunity for an appropriate response to the breach but also of the ability to make an independent assessment of the breach, which, after all, concerns their personal data and may have significant consequences for them. On the other hand, the lack of reporting a personal data breach deprives the supervisory authority of an appropriate response to the breach, which manifests not only in the assessment of the risk of infringement of the rights or freedoms of the individual but also, in particular, in verifying whether the administrator has taken appropriate measures to remedy the breach and minimize negative effects for the data subjects, as well as whether they have implemented appropriate security measures to minimize the risk of recurrence of the breach.

In the factual state of the case at hand, it should be stated that the Administrator, due to the lack of response to requests and the letter informing about the initiation of administrative proceedings, did not demonstrate, in accordance with the principle of accountability referred to in Article 5(2) of Regulation 2016/679, that they conducted a risk assessment of the infringement of the rights or freedoms of individuals in connection with the occurrence of the personal data breach, and consequently did not demonstrate that it is unlikely that the breach could pose a risk to the rights or freedoms of individuals.

At the same time, due to the wide scope of disclosed data (including name and surname and PESEL identification number), it should be stated that as a result of the incident, there was a high risk of infringement of the rights or freedoms of individuals. As indicated by the Article 29 Working Party in the Guidelines on the notification of personal data breaches in accordance with Regulation 2016/679 (WP250rev.01), hereinafter referred to as the "WP250 Guidelines," "This risk exists when a breach may lead to physical harm or material or non-material damage to individuals whose data has been breached. Examples of such damage include discrimination, identity theft or fraud, financial loss, and reputational damage." Furthermore, the Article 29 Working Party in the WP250 Guidelines indicated that the administrator, when assessing the risk to individuals resulting from the breach, should take into account the specific circumstances of the breach, including the severity of the potential impact and the likelihood of its occurrence, and recommended that the criteria indicated in these guidelines be considered during the assessment.

The WP250 Guidelines also clarified that when assessing the risk that may arise as a result of a breach, the administrator should collectively consider the severity of the potential impact on the rights and freedoms of individuals and the likelihood of its occurrence. Of course, the risk increases when the consequences of the breach are more serious, as well as when the likelihood of their occurrence increases. In case of any doubts, the administrator should report the breach, even if such caution might seem excessive.

There is no doubt that the examples of damage cited in the WP250 Guidelines, given the scope of data covered by this personal data breach, including the PESEL identification number along with the name and surname and address of residence, may occur in the discussed case. At this point, it should be noted that the PESEL number, which is an eleven-digit numerical symbol containing the date of birth, serial number, gender designation, and control number, uniquely identifies a specific individual, and thus is closely linked to the private sphere of the individual and as such, consequently, is also subject to exceptional protection under Article 87 of Regulation 2016/679. Given that the PESEL number is a data of a special nature, its disclosure to unauthorized entities may pose a high risk of infringement of the rights or freedoms of individuals (see:

<https://www.bik.pl/poradnik-bik/wyludzenie-kredytu-tak-dzialaja-oszusci> - where a case is described in which "Only the name, surname...

the risk of identity theft or fraud is significantly heightened, as the disclosed data allows for the straightforward identification of individuals affected by the breach."

The PESEL number serves as an identifying data point for each individual and is widely used in interactions with various institutions and in legal transactions. The PESEL number, along with the first and last name, unequivocally identifies a natural person, allowing for the attribution of negative consequences of a breach (e.g., identity theft, loan fraud) to that specific individual.

Considering the above issues, it is also important to reference the position of the Provincial Administrative Court in Warsaw expressed in the judgment of July 1, 2022, in case no. II SA/Wa 4143/21. In the justification of this judgment, the Court stated that: "It should be agreed with the President of the UODO that the loss of confidentiality of the PESEL number in conjunction with personal data such as: first name and last name, registered address, bank account numbers, and the identification number assigned to Bank clients - the CIF number, is associated with a high risk of violation of the rights or freedoms of natural persons. In the event of a breach of such data as first name, last name, and PESEL number, identity theft or forgery may occur, resulting in negative consequences for the individuals whose data is affected. Therefore, the Bank in this case should have promptly, in accordance with Article 34(1) of the GDPR, notified the individuals whose data is concerned about the breach of personal data protection, so as to enable them to take necessary preventive measures." Similarly, the Provincial Administrative Court in Warsaw expressed in its judgment of August 31, 2022, case no. II SA/Wa 2993/21, that "(...) the authority rightly assumed that there was a high risk of violation of the rights and freedoms of individuals affected by the breach due to the possibility of easy identification of the individuals whose data was compromised based on the disclosed data. These data include first name and last name, correspondence address, phone number,

and PESEL number of individuals holding Polish citizenship. In this situation, the risk of identity theft or fraud is significantly heightened, as the disclosed data allows for the straightforward identification of individuals affected by the breach."

Administrator was obliged to notify without undue delay the individuals whose data is concerned about the breach.

From the latest infoDOK report (which is prepared as part of the social Information Campaign of the RESTRICTED DOCUMENTS System, organized by the Polish Bank Association and some banks, under the patronage of the Ministry of Internal Affairs and Administration and in cooperation with, among others, the Police and the Consumers' Federation), it follows that in the third quarter of 2022, there were 2,089 attempts to defraud loans and credits. In the entire year of 2020, there were 6,884 attempts at fraud amounting to 253.8 million PLN, while in the entire year of 2021, there were 8,096 attempts at loan fraud totaling 336.6 million PLN. This means that the entire year of 2021 was significantly more dangerous in terms of the number of fraud attempts and their amounts compared to the previous year: there was a 17% increase in the number of fraud attempts and a 32% increase in the total amount of these fraud attempts.

Moreover, as indicated by the case law, judgments in cases of loan fraud are not uncommon and have been issued by Polish courts in similar cases for a long time - as an example, one can refer to the judgment of the District Court in Łęczyca dated July 27, 2016 (case file I C 566/15), in which the fraudsters taking a loan using someone else's data used a PESEL number, a fictitious address, and an incorrect identification number (invalid). In the justification of the aforementioned judgment, the Court stated: "In the case at hand, the plaintiff (...) based in W. acquired the receivable from (...) Spółka z ograniczoną odpowiedzialnością S.K.A. based in W. The party to the loan agreement dated May 5, 2014, was a person who unlawfully used the data of J. R. (...) Spółka z ograniczoną odpowiedzialnością S.K.A. based in W. transferred the amount of 500 PLN to the indicated bank account. The key issue in this case was to establish that the defendant did not enter into the loan agreement, which was a claim raised by the defendant throughout the proceedings. The conducted evidentiary proceedings and analysis of the documents submitted by the plaintiff lead to the conclusion that it can be unequivocally stated that in the case under consideration, the defendant was not a party to the loan agreement concluded on May 5, 2014. Although the PESEL number of the defendant J. R. was used in its conclusion, the indicated place of residence does not correspond to the residence of the defendant. The defendant J. R. has never lived in W. The loan amount was transferred to an account that was not owned by the defendant. At the time of the conclusion of the loan agreement, the identification document no. (...) had expired on March 15, 2014. The mobile phone number indicated in the loan agreement and its attachments does not match the actual phone numbers used by the defendant. In the context of the case under consideration, the Court found that the defendant demonstrated that she was not a party to the loan agreement that is the subject of these proceedings. Agreements concluded using means of distance communication should require detailed, thorough verification, and such verification conducted in this case leads to the conclusion that the defendant was not a party to the loan agreement."

The obligation to report a breach of personal data protection specified in Article 33(1) of Regulation 2016/679 is also not dependent on whether the risk of infringement of the rights or freedoms of natural persons has materialized. As indicated by the Provincial Administrative Court in Warsaw in the justification of the judgment dated September 22, 2021, case file II SA/Wa 791/21, "It should be emphasized that the possible consequences of the event do not have to materialize. The content of Article 33(1) of Regulation 2016/679 states that the mere occurrence of a breach of personal data protection, which is associated with a risk of infringement of the rights or freedoms of natural persons, implies the obligation to report the breach to the relevant supervisory authority, unless it is unlikely that the breach will result in a risk of infringement of the rights or freedoms of natural persons." Similarly, the WSA in Warsaw stated in the judgment dated January 21, 2022, case file II SA/Wa 1353/21, that "(...) the possible consequences of the event of a breach of personal data do not have to materialize - as Article 33(1) of the GDPR states that the mere occurrence of a breach of personal data protection,

which is associated with a risk of infringement of the rights or freedoms of natural persons, implies the obligation to report the breach to the relevant supervisory authority. The circumstance raised by the Company that no physical harm or damage to natural persons occurred as a result of the breach is irrelevant to determining the existence of the Company's obligation to report the breach of personal data protection to the President of the UODO, in accordance with the aforementioned provision."

In a situation where, as a result of a breach of personal data protection, there is a high risk of infringement of the rights or freedoms of natural persons, the administrator is obliged to implement all appropriate technical and organizational measures to immediately identify the breach of personal data protection and quickly inform the supervisory authority, as well as the individuals whose data are concerned. The administrator should fulfill this obligation as soon as possible.

In Recital 85 of the preamble to Regulation 2016/679, it is explained: "In the absence of an appropriate and rapid response, a breach of personal data protection may result in physical harm, material or non-material damage to natural persons, such as loss of control over their personal data or restriction of rights, discrimination, identity theft or fraud, financial loss, unauthorized reversal of pseudonymization, damage to reputation, breach of confidentiality of personal data protected by professional secrecy, or any other significant economic or social damage. Therefore, immediately after identifying the breach...

****Data Protection Breach****

The administrator should report any breaches of personal data protection to the supervisory authority without undue delay, if feasible, no later than 72 hours after becoming aware of the breach, unless the administrator can demonstrate in accordance with the principle of accountability that the breach is unlikely to result in a risk to the rights or freedoms of natural persons. If it is not possible to make the report within 72 hours, the report should be accompanied by an explanation for the delay, and information may be provided gradually, without further undue delay.

In turn, Recital 86 of the preamble to Regulation 2016/679 states: "The administrator should inform the data subject without undue delay of a personal data breach if it is likely to result in a high risk to the rights or freedoms of that person, so as to enable that person to take the necessary protective measures. Such information should include a description of the nature of the personal data breach and recommendations for the data subject on minimizing the potential adverse effects. Information should be communicated to the data subjects as soon as reasonably feasible, in close cooperation with the supervisory authority, respecting the guidance provided by that authority or other relevant bodies, such as law enforcement authorities. For example, the need to minimize the immediate risk of harm will require informing the data subjects without delay, while the implementation of appropriate measures against similar or analogous personal data breaches may justify a later notification."

By notifying the data subject without undue delay, the administrator enables the individual to take necessary preventive actions to protect their rights or freedoms from the negative effects of the breach. Article 34(1) and (2) of Regulation 2016/679 aims not only to ensure the most effective protection of the fundamental rights or freedoms of data subjects but also to implement the principle of transparency, which arises from Article 5(1)(a) of Regulation 2016/679 (see Witold Chomiczewski [in:] GDPR. General Data Protection Regulation. Commentary, ed. E. Bielak-Jomaa, D. Lubasz, Warsaw 2018). Proper compliance with the obligation specified in Article 34 of Regulation 2016/679 is intended to provide data subjects with prompt and transparent information about the breach of their personal data, along with a description of the possible consequences of the personal data breach and the measures they can take to minimize its potential negative effects. By acting in accordance with the law and demonstrating care for the interests of the data subjects, the administrator should have ensured, without undue delay, the best possible protection of personal data for the individuals concerned. To achieve this goal, it is essential to at least indicate the information specified in Article 34(2) of Regulation 2016/679, which the administrator failed to fulfill. Therefore, by deciding not to notify the supervisory authority and the data subjects about the personal data breach, the administrator effectively deprived those individuals of timely, reliable information about the breach and the opportunity to counter potential damages.

When applying the provisions of Regulation 2016/679, it should be noted that the purpose of this regulation (expressed in Article 1(2)) is to protect the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data, and that the protection of natural persons in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In case of any doubts, for example, regarding the fulfillment of obligations by administrators—not only in situations where there has been a breach of personal data protection but also when developing technical and organizational security measures to prevent such breaches—these values should be taken into account first and foremost.

Consequently, it should be stated that the Administrator did not report the personal data breach to the supervisory authority in fulfillment of the obligation under Article 33(1) of Regulation 2016/679 and did not notify the data subjects without undue delay about the breach of their data, in accordance with Article 34(1) of Regulation 2016/679, which means a violation of these provisions by the Administrator. According to Article 34(4) of Regulation 2016/679, if the administrator has not yet notified the data subject about the personal data breach, the supervisory authority—taking into account the likelihood that the personal data breach will result in a high risk—may require the administrator to do so or may determine that one of the conditions referred to in paragraph 3 has been met. Furthermore, from the content of Article 58(2)(e) of Regulation 2016/679, it follows that each supervisory authority has the corrective power to order the administrator to notify the data subject about the personal data breach.

Based on Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a) - (h) and (j) of this regulation, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. The President of the UODO states that in the case at hand, there were grounds justifying the imposition of an administrative fine on the Administrator based on Article 83(4)(a) of Regulation 2016/679, which states, among other things, that a breach of the administrator's obligations referred to in Articles 33 and 34 of Regulation 2016/679 is subject to an administrative fine. up to 10,000,000 EURO, and in the case of an enterprise - up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount being applicable.

In determining the amount of the fine, the President of the Personal Data Protection Office (UODO) took into account the following circumstances of the case that aggravate the imposed financial penalty: a) The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing in question, the number of affected individuals whose data are involved, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). The Administrator conducts activities related to the assessment and valuation of quality and value in the area of (...). According to the information available on the website: (...), Ms. K.W. serves as a quality expert (...) at the Provincial Inspectorate of Trade Inspection in X., a court expert in quality (...) at the District Court in B., a court expert at the District Court in O., a court expert at the District Court in B., and a tax expert in the valuation of quality and value of movable property in the area of quality (...) at the Tax Chamber in Y. Ms. K.W. is also a certified court mediator.

The infringement identified in this case is of significant weight and serious nature, as reporting personal data breaches by data controllers constitutes an effective tool contributing to a real improvement in the security of personal data processing. Above all, based on the information provided by controllers in personal data breach notifications, the supervisory authority can assess whether the controller has properly analyzed the impact of the breach on the rights or freedoms of the individuals whose data are involved in the breach, and consequently, whether there is a high risk of infringement of the rights or freedoms of natural persons and the necessity to notify those individuals about the breach of their data. Properly executed obligations by controllers as specified in Article 33(1) and 34(1) and (2) of Regulation 2016/679 also allow for the limitation of negative effects of such breaches and the elimination or at least reduction of the risk of such breaches occurring in the future, as controllers are obliged to take actions that ensure proper protection of personal data through the application of appropriate security measures and monitoring their effectiveness.

Furthermore, it should be emphasized that the failure to notify the individuals whose data are concerned about the breach of their personal data may lead to material or non-material damages, and the likelihood of their occurrence is high. The President of UODO considers the long duration of the breach as an aggravating circumstance. From the moment the Administrator became aware of the personal data breach until the date of this decision, more than 12 months have passed, during which the risk of infringement of the rights or freedoms of the individuals affected by the breach could have materialized, and these individuals would not have been able to counteract it due to the Administrator's failure to fulfill the obligation to notify them about the breach. It should also be noted that the administrator directed an inquiry to the President of UODO regarding the theft of documents from his laptop's desktop using a UI application. However, even upon the President of UODO's request, he did not report the personal data breach in the manner specified in Article 33(3) of Regulation 2016/679.

b) The intentional nature of the infringement (Article 83(2)(b) of Regulation 2016/679). According to the Guidelines of the Article 29 Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 WP253 (adopted on October 3, 2017, approved by EDPB on May 25, 2018), intent "includes both knowledge and deliberate action, in relation to the characteristics of the prohibited act." The Administrator made a conscious decision not to notify the President of UODO about the breach, nor the individuals whose data are concerned, despite the fact that the President of UODO had initially informed the Administrator about the obligations arising from the data breach. Ultimately, the mere initiation of these proceedings by the President of UODO regarding the failure to fulfill the obligation to report the personal data breach to the supervisory authority and to notify the individuals whose data are concerned should have raised at least doubts in the Administrator regarding the correctness of his position.

c) The degree of cooperation with the supervisory authority in order to remedy the breach and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). In this case, the President of UODO found that the Administrator did not cooperate at all with the supervisory authority in the performance of its tasks. This assessment pertains to the lack of response from the Administrator to letters sent by the President of UODO informing about the obligations incumbent upon the administrator in connection with the occurrence of the personal data breach, or finally, the lack of response to questions aimed at establishing all circumstances of the personal data breach. The actions deemed appropriate by the President of UODO (reporting the breach to the President of UODO and notifying the individuals concerned about the breach) were not taken by the Administrator even after the initiation of administrative proceedings by the President of UODO in this matter.

d) The categories of personal data involved in the breach (Article 83(2)(g) of Regulation 2016/679). The personal data that were breached do not belong to special categories of personal data referred to in Article 9 of Regulation 2016/679; however, the fact that a wide range of data was involved in the breach (names and surnames, addresses of residence, email addresses, phone numbers, and PESEL numbers), is associated with a high risk of infringement of the rights or freedoms of natural persons. The PESEL number, which is an eleven-digit numerical symbol uniquely identifying a natural person, contains the date of birth, a serial number, a gender designation, and a control number, and is therefore closely linked to the private sphere of the individual and is also subject to, as a national identification number, special protection under Article 87 of Regulation 2016/679. It is data of a special nature and requires such special protection. There is no other, so specific data that would unequivocally identify a natural person. It is no coincidence that the PESEL number serves as identifying data for every individual and is widely used in dealings with various institutions and in legal transactions. The PESEL number, along with the first and last name, unequivocally identifies a natural person in a way that allows for the attribution of negative consequences of an infringement (e.g., identity theft, loan fraud) to that specific individual.

In determining the amount of the administrative monetary penalty, the President of UODO found no grounds to consider mitigating circumstances that would affect the final penalty.

No other circumstances indicated in Article 83(2) of Regulation 2016/679 had any impact on the fact that the President of UODO applied sanctions in the form of an administrative monetary penalty in this case, as well as on its amount:

1. Actions taken by the administrator to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679). Based on the evidence gathered in the case, no such actions were taken by the Administrator.

2. The degree of responsibility of the administrator, taking into account the technical and organizational measures implemented by him under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The infringement assessed in this proceeding (failure to notify the President of UODO of the personal data breach and failure to inform the data subjects of the personal data breach) is not related to the technical and organizational measures employed by the administrator.

3. Relevant previous infringements of the provisions of Regulation 2016/679 by the administrator (Article 83(2)(e) of Regulation 2016/679). The President of UODO found no previous infringements of personal data protection regulations committed by the Administrator, which is why there are no grounds to treat this circumstance as aggravating. And since such a state (compliance with personal data protection regulations) is a natural state resulting from the legal obligations imposed on the Administrator, it cannot also have a mitigating effect on the assessment of the infringement made by the President of UODO.

4. The manner in which the supervisory authority became aware of the infringement (Article 83(2)(h) of Regulation 2016/679). The President of UODO was informed by the Administrator of the occurrence of the infringement of Articles 33(1) and 34(1) of Regulation 2016/679 in connection with an inquiry he made regarding "the theft of documents from my laptop's desktop using the UI application." The Administrator, despite being informed of the procedure to follow in such a situation by the supervisory authority, did not fulfill the obligations indicated in the aforementioned provisions.

5. Compliance with previously applied measures in the same case, as referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Before issuing this decision, the President of UODO did not apply any measures mentioned in Article 58(2) of Regulation 2016/679 to the Administrator in the examined case, which is why the Administrator had no obligation to take any actions related to their application, and such actions, assessed by the President of UODO, could have had an aggravating or mitigating effect on the assessment of the established infringement.

6. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Administrator does not apply the instruments referred to in Articles 40 and 42 of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for administrators and processors, as provided by the provisions of Regulation 2016/679, which is why the circumstance of their non-application cannot be considered detrimental to the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection of processed personal data could be taken into account in favor of the Administrator.

7. Financial benefits obtained directly or indirectly in connection with the infringement or losses avoided (Article 83(2)(k) of Regulation 2016/679). The President of UODO found that the Administrator did not obtain any financial benefits or avoid such losses in connection with the infringement. Therefore, there are no grounds to treat this circumstance as aggravating for the Administrator. The establishment of measurable financial benefits resulting from the infringement of the provisions of Regulation 2016/679 should be assessed very negatively. On the other hand, the Administrator's failure to achieve such benefits, as a natural state independent of the infringement and its consequences, is a circumstance that, by its very nature, cannot be mitigating for the Administrator. This is confirmed by the wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits.

"achieved" - occurred on the part of the entity committing the violation. 8. Other aggravating or mitigating factors applicable to the circumstances of the case (Article 83(2)(k) of Regulation 2016/679). The President of the UODO, having comprehensively considered the case, did not note any circumstances other than those described above that could affect the assessment of the violation and

the amount of the imposed administrative monetary penalty. In the opinion of the President of the UODO, the administrative monetary penalty applied fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportionate, and deterrent in this individual case. It should be emphasized that the penalty will be effective if its imposition leads to the Administrator complying with the applicable legal provisions and permanently ceasing further violations of the provisions of Regulation 2016/679 by failing to report personal data breaches to the President of the UODO and not notifying the individuals concerned about the breaches. The Administrator is an active entity that has been conducting business since (...) October 2016. The President of the UODO established this based on data contained in the Central Register and Information on Economic Activity. The Administrator serves as a quality expert (...) at the Provincial Inspectorate of Trade Inspection in X., a court expert in quality (...) at the District Court in B., a court expert at the District Court in O., a court expert at the District Court in B., a tax expert in assessing the quality and value of movable property in the area of quality (...) at the Tax Chamber in Y. The Administrator is also a certified court mediator. In the opinion of the President of the Personal Data Protection Office, the administrative monetary penalty will serve a repressive function, as it will constitute a response to the Administrator's violation of the provisions of Regulation 2016/679. It will also serve a preventive function; in the opinion of the President of the UODO, it will indicate to both the Administrator and other data controllers the reprehensibility of neglecting the obligations of controllers related to the occurrence of personal data breaches, which aim to prevent their negative and often severe consequences for the individuals concerned, as well as to eliminate these consequences or at least mitigate them. The deterrent nature of the monetary penalty is associated with preventing future violations and placing greater emphasis on the performance of the administrator's tasks. By imposing this administrative decision of a monetary penalty for violating the provisions on personal data protection, the President of the UODO took into account both aspects: firstly - the repressive nature: the Administrator violated the provisions of Regulation 2016/679, secondly - the preventive nature: the Administrator will be effectively discouraged from violating personal data protection law in the future, while also exercising greater diligence in fulfilling their obligations arising from Regulation 2016/679. The purpose of the imposed penalty is to ensure the proper performance by the Administrator of the obligations provided for in Articles 33 and 34 of Regulation 2016/679, and consequently to conduct data processing processes in accordance with applicable legal provisions. In accordance with the provisions of Article 103 of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781), hereinafter referred to as "uodo", the equivalent amounts expressed in euros, referred to in Article 83 of Regulation 2016/679, are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that in a given year the National Bank of Poland does not announce the average euro exchange rate on January 28 - according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date. Having considered the above, the President of the UODO, based on Article 83(4)(a) in conjunction with Article 103 of the uodo, for the violation described in the operative part of this decision, imposed on the Administrator - using the average euro exchange rate from January 30, 2023 (1 EUR = 4.7160 PLN) - an administrative monetary penalty in the amount of 11,790 PLN (which constitutes the equivalent of 2,500 EUR). In the opinion of the President of the UODO, the monetary penalty of 11,790 PLN (in words: eleven thousand seven hundred ninety zlotys) meets the conditions referred to in Article 83(1) of Regulation 2016/679 in the established circumstances of this case due to the seriousness of the established violation in the context of the fundamental purpose of Regulation 2016/679 - the protection of the fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data. The Administrator, despite being summoned, did not submit a financial report. Consequently, the President of the UODO, applying Article 101a(2) of the uodo, determined the amount of the administrative monetary penalty in an estimated manner, taking into account the size of the entity and the specificity of the activity conducted by it. Consequently, in the opinion of the President of the UODO, it will not constitute an excessive burden for him. In this factual and legal state, the President of the Personal Data Protection Office decided as stated in the operative part.

[Print article](#)

[Metadata](#)

Entity providing the information:

Department of Control and Violations

Information created by:

Jan Nowak

2023-07-12

Information entered by:

Wioletta Golańska

2023-09-05 15:06:59

Last modified by:

Edyta Madziar

2023-10-04 12:51:00